

최종 보고서

과업명	유기건 성향 분석 기반 추천 서비스 구축 사업 및 정보보호 체계 강화사업
-----	---

2026년 07월 16일

개 정 이 력

[illegible]

목차

1. 개요.....	5
1.1. 배경 및 목적	5
1.2. 수행 일정 및 수행 내역	5
1.2.1. 수행 일정	5
1.2.2. 수행 인력	6
1.3. 수행 대상	7
1.4. 점검 항목	10
1.4.1. UNIX 서버	10
1.4.2. Window 서버	12
1.4.3. 보안 장비	14
1.4.4. 네트워크 장비	15
1.4.5. PC	16
1.4.6. DBMS	17
1.4.7. Web Application(웹)	18
1.5. 점검 도구	18
2. 결과 요약	19
2.1. 영향도 평가 기준	19
1) 기술적 영향도 (CVSS 기반)	19
2) 자산 중요도에 따른 영향 조정	19
3) 종합 평가 방식	20
2.2. 총평	20
2.3. 취약점 요약	Error! Bookmark not defined.
3. 상세 수행 내역	20
3.1. 취약점 진단	20
3.1.1. 서버(Linux) 요약	20
3.1.2. 서버(Windows) 요약	21
3.1.3. PC(Windows) 요약	21
3.1.4. DBMS 요약	21
3.1.5. 네트워크 요약	22
3.1.6. 보안장비 요약	22

3.2. 시나리오 기반 모의해킹 및 위험 분석	23
3.2.1. 시나리오 기반 모의해킹 검증 내용, 간단한 위험 분석 내용	23

1. 개요

1.1. 배경 및 목적

본 사업은 딩동독(DingDongDog!) 플랫폼의 핵심 데이터 보호와 서비스 무결성 확보를 최우선 과제로 수행한다. 네트워크 망 분리와 다층 방어 체계를 통해 외부 위협을 원천 차단하고, 엄격한 접근 제어와 정기적인 취약점 점검을 통해 보안 체계를 상시 최적화한다. 또한, 고도화된 통합 보안 관제 체계를 수립하여 침해 사고에 대한 선제적 대응 역량을 강화함으로써, 이용자가 안심할 수 있는 안전하고 견고한 플랫폼 운영 기반을 마련하고자 한다.

1.2. 수행 일정 및 수행 내역

1.2.1. 수행 일정

	Task	기간	산출물	담당자
1. 프로젝트 관리	1.1 제안서 작성	6/4 ~ 6/6 (3d)	제안서	PM
	1.2 일정 수립	6/4 ~ 6/5 (2d)	WBS	PM
	1.3 킥 오프 미팅	6/9 (1d)	Kick-off 회의록	PM/전체
2. 취약점 분석 및 평가	2.1 취약점 점검 대상 식별 및 분류	6/9 ~ 6/12 (4d)	점검 대상 목록	PM/전체
	2.2 취약점 본 점검 수행	6/15 ~ 6/25 (11d)	취약점 상세 결과 보고서	전체
	2.3 취약점 위험 분석/평가 수행	6/20 ~ 6/24 (5d)	취약점 평가 보고	전체
3. 보안대책 수립 및 조치 지원	3.1 취약점 개선 방안 도출	6/24 ~ 6/27 (4d)	취약점 상세 결과 보고서	전체
	3.2 인프라 구성 및 시스템 구축(보안설정)	6/24 ~ 7/7 (14d)	보안설정 적용 내역	전체
4. 모의해킹	4.1 모의해킹	6/29 ~ 7/8 (10d)	모의해킹 결과 보고서	모의해킹 팀
	4.2 모의해킹 보안설정	7/8 ~ 7/14 (7d)	보안설정 적용 내역	모의해킹 팀

5. 문서화 및 보고	5.2 문서화 작업	7/6 ~ 7/15 (10d)	문서화 정리	PM/전체
	5.3 최종 보고	7/16 (1d)	최종 보고서	PM/전체

1.2.2. 수행 인력

담당자	수행 내역	e-mail
서서울	PM	scity9799@gmail.com
	본사/지사 리눅스 보안 설정	
	DBMS 서버 보안 설정	
	지사 윈도우 서버 보안설정	
	모의해킹 및 이행 점검 수행	
윤철민	PL	mickyun1633@gmail.com
	본사/지사 윈도우 서버 보안설정	
	본사/지사 윈도우 서버 점검	
	보안장비 점검, 보안 설정	
오명근	본사/지사 네트워크 보안 설정	lalalu0321@gmail.com
	본사/지사 윈도우 서버 보안설정	
	사용자 PC 점검, 보안 설정	
	DBMS 서버 점검	
	본사/지사 리눅스 서버 점검	
서정원	본사/지사 네트워크 보안 설정	kororo62310@gmail.com
	본사 네트워크 점검	
	보안장비 점검, 보안 설정	
이주환	본사/지사 네트워크 보안 설정	concept8460@gmail.com
	지사 네트워크 점검	
	모의해킹 및 이행 점검 수행	

1.3. 수행 대상

자산정보						
대분류	NO	자산식별	Hostname	IP	OS Ver.	용도
Linux server	lin01	SV-03	LOG_HQ_Rocky	10.10.40.3	Rocky Linux 8.10	Log 서버
	lin02	SV-05	DB_HQ_Rocky	10.10.40.18	Rocky Linux 8.10	DB 서버
	lin05	SV-08	PHP_BR_Rocky	10.200.40.1	Rocky Linux 8.10	PHP 서버
	lin06	SV-10	LOG_BR_Rocky	10.200.40.3	Rocky Linux 8.10	Log 서버
	lin07	SV-12	DB_BR_Rocky	10.200.40.18	Rocky Linux 8.10	DB 서버
Windows server	win01	SV-02	DNS_HQ_Win	10.10.40.2	Windows server 2016	DNS 서버
	win02	SV-04	DHCP_HQ_Win	10.10.40.17	Windows server 2016	DHCP 서버
	win03	SV-09	DNS_BR_Win	10.200.40.2	Windows server 2016	DNS 서버
	win04	SV-11	DHCP_BR_Win	10.200.40.17	Windows server 2016	DHCP 서버
Network	NW01	NT-01	HQ-EDGE-FW	10.10.40.234 10.10.40.237	Cisco IOS 15.x	외부망 방화벽, UTM
	NW02	NT-02	HQ-SCREENING-R	10.10.40.233	Cisco IOS 15.x	스크리닝 라우터
	NW03	NT-03	HQ-DMZ-L3	10.10.40.14 10.10.40.238 10.10.40.241	Cisco IOS 15.x	DMZ L3Switch
	NW04	NT-04	HQ-INTERNAL-FW-R	10.10.40.242 10.10.40.249 10.10.40.253	Cisco IOS 15.x	내부 라우터

	NW05	NT-05	HQ-CORE-L3-A	10.10.40.28 10.10.40.36 10.10.40.68 10.10.40.92 10.10.40.108 10.10.40.116 10.10.40.250	Cisco IOS 15.x	본사 L3 Switch A
	NW06	NT-06	HQ-CORE-L3-B	10.10.40.37 10.10.40.29 10.10.40.69 10.10.40.93 10.10.40.109 10.10.40.117 10.10.40.254	Cisco IOS 15.x	본사 L3 Switch B
	NW07	NT-07	HQ-SERVER-L2	-	Cisco IOS 15.x	서버망 L2Switch
	NW08	NT-08	HQ-BACKUP-L2	-	Cisco IOS 15.x	백업망 L2 Switch
	NW09	NT-09	HQ-HR-L2	-	Cisco IOS 15.x	인사팀 L2 Switch
	NW10	NT-10	HQ-DEV-L2	-	Cisco IOS 15.x	개발팀 L2 Switch
	NW11	NT-11	HQ-OPS-L2	-	Cisco IOS 15.x	운영팀 L2 Switch
	NW12	NT-12	HQ-CS-L2	-	Cisco IOS 15.x	CS 팀 L2Switch
	NW13	NT-13	BR-EDGE-FW	10.200.40.234 10.200.40.237	Cisco IOS 15.x	지사 경계 방화벽, UTM
	NW14	NT-14	BR-SCREENING-R	10.200.40.233	Cisco IOS 15.x	지사 스크리닝 라우터
	NW15	NT-15	BR-DMZ-L3	10.200.40.6 10.200.40.9	Cisco IOS 15.x	지사 DMZ L3 Switch

				10.200.40.14		
	NW16	NT-16	BR-INTERNAL-FW-R	10.200.40.242 10.200.10.249 10.200.20.253	Cisco IOS 15.x	지사 내부 라우터
	NW17	NT-17	BR-CORE-L3-A	10.200.40.28 10.200.40.36 10.200.40.68 10.200.40.92 10.200.40.108 10.200.40.116 10.200.40.250	Cisco IOS 15.x	지사 L3 Switch A
	NW18	NT-18	BR-CORE-L3-B	10.200.40.37 10.200.40.29 10.200.40.69 10.200.40.93 10.200.40.109 10.200.40.117 10.200.40.254	Cisco IOS 15.x	지사 L3 Switch B
	NW19	NT-19	BR-SERVER-L2	-	Cisco IOS 15.x	지사 서버망 L2 Switch
	NW20	NT-20	BR-LOGISTICS-SW	-	Cisco IOS 15.x	물류팀 L2 Switch
	NW21	NT-21	BR-OPS-SW	-	Cisco IOS 15.x	지사 운영팀 L2 Switch
	NW22	NT-22	BR-CS-SW	-	Cisco IOS 15.x	지사 CS 팀 L2 Switch
PC	PC01	PC-01	HQ_DEV01	10.10.40.81	Windows 11 pro	본사 개발팀 PC
보안장비	SC01	SPY-01	SC-SPY	192.168.20.222	SpiderTM	로그 모니터링
	SC02	SPY-02	HQ-WAF	10.10.40.13	-	웹 방화벽

1.4. 점검 항목

『주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드』에 따라 수행되었으며, 다음과 같이 시스템 유형별로 구분된 점검 항목을 기준으로 기술적 보안 점검을 진행하였습니다.

1.4.1. UNIX 서버

	점검항목	항목 중요도	항목코드
1. 계정 관리	root 계정 원격 접속 제한	상	U-01
	비밀번호 관리정책 설정	상	U-02
	계정 잠금 임계값 설정	상	U-03
	비밀번호 파일 보호	상	U-04
	root 이외의 UID가 '0' 금지	상	U-05
	사용자 계정 su 기능 제한	상	U-06
	불필요한 계정 제거	하	U-07
	관리자 그룹에 최소한의 계정 포함	중	U-08
	계정이 존재하지 않는 GID 금지	하	U-09
	동일한 UID 금지	중	U-10
	사용자 Shell 점검	하	U-11
	세션 종료 시간 설정	하	U-12
	안전한 비밀번호 암호화 알고리즘 사용	중	U-13
2. 파일 및 디렉토리 관리	root 홈, 패스 디렉터리 권한 및 패스 설정	상	U-14
	파일 및 디렉터리 소유자 설정	상	U-15
	/etc/passwd 파일 소유자 및 권한 설정	상	U-16
	시스템 시작 스크립트 권한 설정	상	U-17
	/etc/shadow 파일 소유자 및 권한 설정	상	U-18
	/etc/hosts 파일 소유자 및 권한 설정	상	U-19
	/etc/(x)inetd.conf 파일 소유자 및 권한 설정	상	U-20
	/etc/(r)syslog.conf 파일 소유자 및 권한 설정	상	U-21
	/etc/services 파일 소유자 및 권한 설정	상	U-22
	SUID, SGID, Sticky bit 설정 파일 점검	상	U-23
	사용자, 시스템 환경변수 파일 소유자 및 권한 설정	상	U-24

	world writable 파일 점검	상	U-25
	/dev에 존재하지 않는 device 파일 점검	상	U-26
	\$HOME/.rhosts, hosts.equiv 사용 금지	상	U-27
	접속 IP 및 포트 제한	상	U-28
	hosts.lpd 파일 소유자 및 권한 설정	하	U-29
	UMASK 설정 관리	중	U-30
	홈 디렉터리 소유자 및 권한 설정	중	U-31
	홈 디렉터리로 지정한 디렉터리의 존재 관리	중	U-32
	숨겨진 파일 및 디렉터리 검색 및 제거	하	U-33
3. 서비스 관리	Finger 서비스 비활성화	상	U-34
	공유 서비스에 대한 익명 접근 제한 설정	상	U-35
	r 계열 서비스 비활성화	상	U-36
	crontab 설정파일 권한 설정 미흡	상	U-37
	DoS 공격에 취약한 서비스 비활성화	상	U-38
	불필요한 NFS 서비스 비활성화	상	U-39
	NFS 접근 통제	상	U-40
	불필요한 automountd 제거	상	U-41
	불필요한 RPC 서비스 비활성화	상	U-42
	NIS, NIS+ 점검	상	U-43
	tftp, talk 서비스 비활성화	상	U-44
	메일 서비스 버전 점검	상	U-45
	일반 사용자의 메일 서비스 실행 방지	상	U-46
	스팸 메일 릴레이 제한	상	U-47
	expn, vrfy 명령어 제한	중	U-48
	DNS 보안 버전 패치	상	U-49
	DNS Zone Transfer 설정	상	U-50
	DNS 서비스의 취약한 동적 업데이트 설정 금지	중	U-51
	Telnet 서비스 비활성화	중	U-52
	FTP 서비스 정보 노출 제한	하	U-53
	암호화되지 않는 FTP 서비스 비활성화	중	U-54
	FTP 계정 Shell 제한	중	U-55
	FTP 서비스 접근 제어 설정	하	U-56
	Ftpusers 파일 설정	중	U-57
	불필요한 SNMP 서비스 구동 점검	중	U-58
	안전한 SNMP 버전 사용	상	U-59
	SNMP Community String 복잡성 설정	중	U-60

	SNMP Access Control 설정	상	U-61
	로그인 시 경고 메시지 설정	하	U-62
	sudo 명령어 접근 관리	중	U-63
4. 패치 관리	주기적 보안 패치 및 벤더 권고사항 적용	상	U-64
5. 로그 관리	NTP 및 시각 동기화 설정	중	U-65
	정책에 따른 시스템 로깅 설정	중	U-66
	로그 디렉터리 소유자 및 권한 설정	중	U-67

1.4.2. Window 서버

	점검항목	항목 중요도	항목코드
1. 계정 관리	Administrator 계정 이름 변경 등 보안성 강화	상	W-01
	Guest 계정 비활성화	상	W-02
	불필요한 계정 제거	상	W-03
	계정 잠금 임계값 설정	상	W-04
	해독 가능한 암호화를 사용하여 암호 저장 해제	상	W-05
	관리자 그룹에 최소한의 사용자 포함	상	W-06
	Everyone 사용 권한을 익명 사용자에게 적용	중	W-07
	계정 잠금 기간 설정	중	W-08
	비밀번호 관리정책 설정	상	W-09
	마지막 사용자 이름 표시 안 함	중	W-10
	로컬 로그인 허용	중	W-11
	익명 SID/이름 변환 허용 해제	중	W-12
	콘솔 로그인 시 로컬 계정에서 빈 암호 사용 제한	중	W-13
	원격터미널 접속 가능한 사용자 그룹 제한	중	W-14
2. 서비스 관리	사용자 개인키 사용 시 암호 입력	상	W-15
	공유 권한 및 사용자 그룹 설정	상	W-16
	하드디스크 기본 공유 제거	상	W-17
	불필요한 서비스 제거	상	W-18
	불필요한 IIS 서비스 구동 점검	상	W-19
	NetBIOS 바인딩 서비스 구동 점검	상	W-20
	암호화되지 않는 FTP 서비스 비활성화	상	W-21
	FTP 디렉토리 접근권한 설정	상	W-22

	공유 서비스에 대한 익명 접근 제한 설정	상	W-23
	FTP 접근 제어 설정	상	W-24
	DNS Zone Transfer 설정	상	W-25
	RDS(Remote Data Services)제거	상	W-26
	최신 Windows OS Build 버전 적용	상	W-27
	터미널 서비스 암호화 수준 설정	중	W-28
	불필요한 SNMP 서비스 구동 점검	중	W-29
	SNMP Community String 복잡성 설정	중	W-30
	SNMP Access control 설정	중	W-31
	DNS 서비스 구동 점검	중	W-32
	HTTP/FTP/SMTP 배너 차단	하	W-33
	Telnet 서비스 비활성화	중	W-34
	불필요한 ODBC/OLE-DB 데이터 소스와 드라이버 제거	중	W-35
	원격터미널 접속 타임아웃 설정	중	W-36
	예약된 작업에 의심스러운 명령이 등록되어 있는지 점검	중	W-37
3. 패치 관리	주기적 보안 패치 및 벤더 권고사항 적용	상	W-38
	백신 프로그램 업데이트	상	W-39
4. 로그 관리	정책에 따른 시스템 로깅 설정	중	W-40
	NTP 및 시각 동기화 설정	중	W-41
	이벤트 로그 관리 설정	하	W-42
	이벤트 로그 파일 접근 통제 설정	중	W-43
	원격으로 액세스할 수 있는 레지스트리 경로	상	W-44
5. 보안 관리	백신 프로그램 설치	상	W-45
	SAM 파일 접근 통제 설정	상	W-46
	화면보호기 설정	상	W-47
	로그온하지 않고 시스템 종료 허용	상	W-48
	원격 시스템에서 강제로 시스템 종료	상	W-49
	보안 감사를 로그 할 수 없는 경우 즉시 시스템 종료	상	W-50
	SAM 계정과 공유의 익명 열거 허용 안 함	상	W-51
	Autologon 기능 제어	상	W-52
	이동식 미디어 포맷 및 꺼내기 허용	상	W-53
	Dos공격 방어 레지스트리 설정	중	W-54
	사용자가 프린터 드라이버를 설치할 수 없게 함	중	W-55

	SMB 세션 중단 관리 설정	중	W-56
	로그온 시 경고 메시지 설정	하	W-57
	사용자별 홈 디렉터리 권한 설정	중	W-58
	LAN Manager 인증 수준	중	W-59
	보안 채널 데이터 디지털 암호화 또는 서명	중	W-60
	파일 및 디렉토리 보호	중	W-61
	시작프로그램 목록 분석	중	W-62
	도메인 컨트롤러-사용자의 시간 동기화	중	W-63
	윈도우 방화벽 설정	중	W-64

1.4.3. 보안 장비

	점검항목	항목 중 요도	항목코드
1. 계정 관리	보안 장비 Default 계정명 변경	상	S-01
	비밀번호 관리정책 설정	상	S-02
	보안 장비 계정별 권한 설정	상	S-03
	보안 장비 계정 관리	상	S-04
	계정 잠금 임계값 설정	상	S-05
2. 접근 관리	보안장비 원격 관리 접근 통제	상	S-06
	보안장비 보안 접속	상	S-07
	세션 종료 시간 설정	상	S-08
3. 패치 관리	주기적 보안 패치 및 벤더 권고사항 적용	상	S-09
4. 로그 관리	보안장비 로그 설정	중	S-10
	보안장비 로그 보관	중	S-11
	보안장비 정책 백업 설정	중	S-12
	원격 로그 서버 사용	중	S-13
	NTP 및 시각 동기화 설정	중	S-14
5. 기능 관리	정책 관리	상	S-15
	NAT 설정	상	S-16
	DMZ 설정	상	S-17
	최소한의 서비스만 제공	상	S-18
	이상징후 탐지 모니터링 수행	상	S-19
	장비 사용량 검토	상	S-20
	SNMP 서비스 확인	상	S-21
	SNMP Community String 복잡성 설정	상	S-22

	유해 트래픽 탐지/차단 정책 설정	중	S-23
--	--------------------	---	------

1.4.4. 네트워크 장비

	점검항목	항목 중요도	항목코드
1. 계정 관리	비밀번호 설정	상	N-01
	비밀번호 복잡성 설정	상	N-02
	암호화된 비밀번호 가용	상	N-03
	계정 잠금 임계값 설정	상	N-04
	사용자, 명령어별 권한 수준 설정	중	N-05
2. 접근 관리	VTY 접근(ACL) 설정	상	N-06
	세션 종료 시간 설정	상	N-07
	VTY 접속 시 안전한 프로토콜 사용	중	N-08
	불필요한 보조 입출력 포트 사용 금지	중	N-09
	로그온 시 경고 메시지 설정	중	N-10
	원격 로그 서버 사용	중	N-11
3. 패치 관리	주기적 보안 패치 및 벤더 권고사항 적용	상	N-12
4. 로그 관리	로깅 버퍼 크기 설정	중	N-13
	정책에 따른 로깅 설정	중	N-14
	NTP 및 시각 동기화 설정	중	N-15
	Timestamp 로그 설정	하	N-16
5. 기능 관리	SNMP 서비스 확인	상	N-17
	SNMP Community String 복잡성 설정	상	N-18
	SNMP ACL 설정	상	N-19
	SNMP Community 권한 설정	상	N-20
	TFTP 서비스 차단	상	N-21
	Spoofing 방지 필터링 적용	상	N-22
	DDoS 공격 방어 설정 또는 DDoS 장비 사용	상	N-23
	사용하지 않는 인터페이스 비활성화	상	N-24
	TCP Keepalive 서비스 설정	중	N-25
	Finger 서비스 차단	중	N-26
	웹 서비스 차단	중	N-27
	TCP/UDP small 서비스 차단	중	N-28
	Bootp 서비스 차단	중	N-29
	CDP 서비스 차단	중	N-30

	Directed-broadcast 차단	중	N-31
	Source 라우팅 차단	중	N-32
	Proxy ARP 차단	중	N-33
	ICMP unreachable, Redirect 차단	중	N-34
	identd 서비스 차단	중	N-35
	Domain Lookup 차단	중	N-36
	pad 차단	중	N-37
	mask-reply 차단	중	N-38

1.4.5. PC

	점검항목	항목 중요도	항목코드
1. 계정 관리	비밀번호의 주기적 변경	상	PC-01
	비밀번호 관리정책 설정	상	PC-02
	복구 콘솔에서 자동 로그인을 금지하도록 설정	중	PC-03
2. 서비스 관리	공유 폴더 제거	상	PC-04
	항목의 불필요한 서비스 제거	상	PC-05
	비인가 상용 메신저 사용 금지	상	PC-06
	파일 시스템이 NTFS 포맷으로 설정	중	PC-07
	대상 시스템이 Windows 서버를 제외한 다른 OS로 멀티 부팅이 가능하지 않도록 설정	중	PC-08
	브라우저 종료 시 임시 인터넷 파일 폴더의 내용을 삭제하도록 설정	하	PC-09
3. 패치 관리	주기적 보안 패치 및 벤더 권고사항 적용	상	PC-10
	지원이 종료되지 않은 Windows OS Build 적용	상	PC-11
4. 보안 관리	Windows 자동 로그인 점검	중	PC-12
	바이러스 백신 프로그램 설치 및 주기적 업데이트	상	PC-13
	바이러스 백신 프로그램에서 제공하는 실시간 감시 기능 활성화	상	PC-14
	OS에서 제공하는 침입차단 기능 활성화	상	PC-15
	화면보호기 대기 시간 설정 및 재시작 시 암호 보호 설정	상	PC-16
	CD, DVD, USB 메모리 등과 같은 미디어의 자동실행 방지 등 이동식 미디어에 대한 보안대	상	PC-17

	책 수립		
	원격 지원을 금지하도록 정책을 설정	중	PC-18

1.4.6. DBMS

	점검항목	항목 중요도	항목코드
1. 계정 관리	기본 계정의 비밀번호, 정책 등을 변경하여 사용	상	D-01
	데이터베이스의 불필요 계정을 제거하거나, 잠금설정 후 사용	상	D-02
	비밀번호의 사용기간 및 복잡도를 기관의 정책에 맞도록 설정	상	D-03
	데이터베이스 관리자 권한을 꼭 필요한 계정 및 그룹에 대해서만 허용	상	D-04
	비밀번호 재사용에 대한 제약 설정	중	D-05
	DB 사용자 계정을 개별적으로 부여하여 사용	중	D-06
	root 권한으로 서비스 구동 제한	중	D-07
	안전한 암호화 알고리즘 사용	상	D-08
	일정 횟수의 로그인 실패 시 이에 대한 잠금정책 설정	중	D-09
2. 접근 관리	원격에서 DB 서버로의 접속 제한	상	D-10
	DBA 이외의 인가되지 않은 사용자가 시스템 테이블에 접근할 수 없도록 설정	상	D-11
	안전한 리스너 비밀번호 설정 및 사용	상	D-12
	불필요한 ODBC/OLE-DB 데이터 소스와 드라이버를 제거하여 사용	중	D-13
	데이터베이스의 주요 설정파일, 비밀번호 파일 등과 같은 주요 파일들의 접근 권한이 적절하게 설정	중	D-14
	관리자 이외의 사용자가 오라클 리스너의 접속을 통해 리스너 로그 및 trace 파일에 대한 변경 제한	하	D-15
	Windows 인증 모드 사용	하	D-16
3. 옵션 관리	Audit Table은 데이터베이스 관리자 계정에 접근하도록 제한	하	D-17
	응용프로그램 또는 DBA 계정의 Role이 Public으로 설정되지 않도록 조정	상	D-18

	OS_ROLES, REMOTE_OS_AUTHENTICATION, REMOTE_OS_ROLES를 FALSE로 설정	상	D-19
	인가되지 않은 Object owner의 제한	하	D-20
	인가되지 않은 GRANT OPTION 사용 제한	중	D-21
	데이터베이스의 자원 제한 기능을 TRUE로 설정	하	D-22
	xp_cmdshell 사용 제한	상	D-23
	Registry Procedure 권한 제한	상	D-24
4. 패치 관리	주기적 보안 패치 및 벤더 권고사항 적용	상	D-25
	데이터베이스의 접근, 변경, 삭제 등의 감사 기록이 기관의 감사 기록 정책에 적합하도록 설정	상	D-26

1.4.7. Web Application(웹)

점검항목	항목 중요도	항목코드
SQL 인젝션 (SQL Injection)	상	SI
디렉터리 인덱싱	상	DI
에러 페이지 적용 미흡	상	EP
정보 누출	상	IL
크로스사이트 스크립트	상	XS
크로스사이트 요청 위조(CSRF)	상	CF
약한 비밀번호 정책	상	BF
불충분한 인증 절차	상	IA
프로세스 검증 누락	상	PV
악성 파일 업로드	상	FU
파일 다운로드	상	FD
불충분한 세션 관리	상	IS
데이터 평문 전송	상	SN
쿠키 변조	상	CC
관리자 페이지 노출	상	AE

1.5. 점검 도구

본 점검사항을 수행하면서 사용된 도구는 아래 표와 같다.

도구 이름	용도	사이트
Burp Suite	웹 애플리케이션 프록시 패킷 변조를 통한 인증 우회, 파라미터 조작, 인젝션 취약점 수동 진단	http://portswigger.net/Burp/
PuTTY	Unix 서버 원격 보안 설정을 위한 SSH 접속	https://putty.softonic.kr/
Nmap	네트워크 장비 및 서버의 활성 포트 스캐닝, 불필요한 서비스 구동 여부 확인	nmap.org
Wireshark	네트워크 패킷 캡처를 통한 평문 프로토콜 전송 및 암호화 미적용 구간 진단	wireshark.org

2. 결과 요약

2.1. 영향도 평가 기준

본 보고서에서는 취약점의 영향도를 국제 표준인 CVSS v3.1(Common Vulnerability Scoring System) 점수를 기반으로 산정하되, 실제 자산의 중요도와 업무적 영향도까지 함께 고려하여 종합적인 위험 수준을 평가하였습니다.

평가 결과는 '상(High)', '중(Medium)', '하(Low)' 3 단계로 구분되며, 아래와 같은 기준에 따라 최종 영향도를 판단합니다.

1) 기술적 영향도 (CVSS 기반)

점수 범위	영향도	설명
7.0 ~ 10.0	상 (High)	시스템 치명적 영향, 관리자 권한 탈취, 대량 정보 유출
4.0 ~ 6.9	중 (Medium)	제한적 정보 노출, 인증 우회, 설정 오류 등
0.1 ~ 3.9	하 (Low)	정보 수집 수준, 시스템 운영에 큰 영향 없음

2) 자산 중요도에 따른 영향 조정

동일한 취약점이라도 위치한 자산의 중요도에 따라 최종 영향도는 상이할 수 있으며, 아래 기준을 참고하여 평가하였습니다.

자산 유형	설명	영향도 적용 예시
핵심 자산	DB, 인증 서버, 보안 시스템 등 핵심 운영 자산	동일 취약점도 '상'으로 평가
일반 자산	내부 포털, 업무용 시스템 등 일반적 업무 자산	'중' 또는 '하'로 평가

비핵심 자산	테스트 서버, 개발 장비, 비업무성 자산	'하'로 평가
--------	---------------------------	---------

3) 종합 평가 방식

최종 영향도는 CVSS 기술 점수와 자산 중요도를 조합하여 결정하며, 단순한 수치 이상으로 업무적 현실성과 대응 우선순위를 고려한 종합적 판단입니다.

예시 : 동일한 CVSS 7.5 의 취약점이라도, DB 서버에서는 '상', 테스트 서버에서는 '중' 또는 '하'로 판단됩니다.

2.2. 총평

이번 보안 점검 결과, 리눅스 서버·DBMS·네트워크 장비·Windows PC 전반에서 계정 관리, 접근 통제, 패치 관리, 서비스 및 옵션 설정, 로그·감사 기능 등 기본 보안 운영체계가 안정적으로 구축되어 있음이 공통적으로 확인되었습니다. 특히 중요도 High 항목을 포함한 주요 보안 지표에서 취약점 없이 우수한 방어 태세를 유지하고 있어, 외부의 공격 시도는 물론 내부적인 위험 확산을 원천 차단할 수 있는 견고한 환경을 형성하고 있습니다. 리눅스 서버와 네트워크 장비는 철저한 서비스 설정, 강력한 접근 제어, 불필요한 서비스의 완벽한 비활성화가 이루어져 침해사고 발생 가능성을 최소화하고 피해 확산 경로를 성공적으로 차단한 것으로 평가되었으며, DBMS는 체계적인 권한 관리와 촘촘한 로그 기록 기능을 통해 정보 유출 및 권한 탈취 위험을 완벽히 해소하고 있습니다. Windows PC 또한 최신 패치 적용과 엄격한 정책 설정을 통해 악성코드 감염 가능성을 원천적으로 배제하고 있습니다. 이에 따라 표준화된 보안정책, 확립된 패치 관리 체계, 강화된 계정·권한 관리 등 전사적 보안 체계가 높은 수준으로 정착되어 있으며, 전체 인프라의 우수한 보안 성숙도를 지속적으로 유지하기 위한 안정적인 관리·감독이 원활하게 이루어지고 있습니다.

3. 상세 수행 내역

3.1. 취약점 진단

3.1.1. 서버(Linux) 요약

Linux 서버를 대상으로 수행한 이행 점검 보안취약점 진단 결과, 전체적인 보안 수준은 100.0%로 확인되었으며, 모든 점검 항목에서 권고사항이 정상적으로 반영되어 우수 상태로 평가되었습니다. 각 항목별 이행 결과는 다음과 같습니다.

계정 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 모든 권고사항이 정상 적용되었습니다. 파일 및 디렉터리 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 점검된 항목에 대해 모두 적절한 보완이 이루어졌습니다. 서비스 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 주요 서비스 설정 및 접근 제어 항목에 대한 조치가 완료되었습니다. 로그 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 로그 수집 및 보존 정책이 모두 적절히 적용되었습니다.

3.1.2. 서버(Windows) 요약

Windows 서버를 대상으로 수행한 이행 점검 보안취약점 진단 결과, 전체적인 보안 수준은 100.0%로 확인되었으며, 모든 점검 항목에서 권고사항이 정상적으로 반영되어 우수 상태로 평가되었습니다. 각 항목별 이행 결과는 다음과 같습니다.

계정 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 모든 권고사항이 정상 적용되었습니다. 서비스 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 주요 서비스 설정 및 접근 제어 항목에 대한 조치가 완료되었습니다. 패치 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 필요한 보안 패치 및 업데이트 적용이 완료되었습니다. 로그 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 로그 수집 및 보존 정책이 모두 적절히 적용되었습니다. 보안 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 정책 설정 및 시스템 보안 제어 항목에 대한 보완이 완료되었습니다.

3.1.3. PC(Windows) 요약

Windows PC 를 대상으로 수행한 이행 점검 보안취약점 진단 결과, 전체적인 보안 수준은 100.0%로 확인되었으며, 모든 점검 항목에서 권고사항이 정상적으로 반영되어 우수 상태로 평가되었습니다. 각 항목별 이행 결과는 다음과 같습니다.

계정 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 모든 권고사항이 정상 적용되었습니다. 서비스 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 주요 서비스 설정 및 접근 제어 항목에 대한 조치가 완료되었습니다. 패치 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 필요한 보안 패치 및 업데이트 적용이 완료되었습니다. 보안 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 정책 설정 및 단말 보안 제어 항목에 대한 보완이 완료되었습니다.

3.1.4. DBMS 요약

DBMS 를 대상으로 수행한 이행 점검 보안취약점 진단 결과, 전체적인 보안 수준은 100.0%로 확인되었으며, 모든 점검 항목에서 권고사항이 정상적으로 반영되어 우수 상태로 평가되었습니다. 각 항목별 이행 결과는 다음과 같습니다.

계정 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 모든 권고사항이 정상 적용되었습니다. 접근 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 주요 권한 제어 및 접근 통제 항목에 대한 조치가 완료되었습니다. 로그 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 감사 로그 수집 및 보존 정책이 모두 적절히 적용되었습니다.

3.1.5. 네트워크 요약

네트워크 장비를 대상으로 수행한 이행 점검 보안취약점 진단 결과, 전체적인 보안 수준은 100.0%로 확인되었으며, 모든 점검 항목에서 권고사항이 정상적으로 반영되어 우수 상태로 평가되었습니다. 각 항목별 이행 결과는 다음과 같습니다.

계정 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 모든 권고사항이 정상 적용되었습니다. 패치 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 필요한 보안 패치 및 업데이트 적용이 완료되었습니다. 서비스 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 주요 서비스 설정 및 접근 제어 항목에 대한 조치가 완료되었습니다. 로그 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 로그 수집 및 보존 정책이 모두 적절히 적용되었습니다.

3.1.6. 보안장비 요약

보안장비를 대상으로 수행한 이행 점검 보안취약점 진단 결과, 전체적인 보안 수준은 100.0%로 확인되었으며, 모든 점검 항목에서 권고사항이 정상적으로 반영되어 우수 상태로 평가되었습니다. 각 항목별 이행 결과는 다음과 같습니다.

계정 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 모든 권고사항이 정상 적용되었습니다. 접근 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 관리자 접속 제한, 보안 접속 및 세션 관리 항목에 대한 조치가 완료되었습니다. 패치 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 필요한 보안 패치 및 업데이트 적용이 완료되었습니다. 로그 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 로그 수집, 보존, 백업 및 원격 전송 설정이 모두 적절히 적용되었습니다. 기능 관리 영역의 보안 수준은 100.0%로, 우수 수준으로 평가되며, 정책 관리, 이상징후 탐지, 유해 트래픽 차단 및 장비 기능별 보안 설정에 대한 보완이 완료되었습니다.

3.2. 시나리오 기반 모의해킹 및 위험 분석

3.2.1. 시나리오 기반 모의해킹 검증 내용, 간단한 위험 분석 내용

본 모의해킹 프로젝트는 디동독 플랫폼의 보안성 검증을 위해 수행되었으며, 진단 결과 데이터 처리 로직 및 인증 체계 전반에서 다수의 고위험 취약점이 발견되었습니다.

입력 값 검증 부재에 따른 코드 인젝션 위험

핵심 서비스인 게시판, 로그인 등 사용자 입력 처리 구역에서 SQL Injection 및 XSS 취약점이 확인되었습니다. 특히 입력 값에 대한 화이트리스트 검증 로직이 부재하여, 공격자가 악의적인 SQL 구문을 주입해 데이터베이스 무결성을 훼손하거나, 스크립트를 삽입하여 사용자 세션을 탈취할 수 있는 구조적 결함이 노출되었습니다. 또한, 디렉터리 인덱싱이 활성화되어 있어 시스템 내부 경로와 설정 파일이 외부에 노출되는 문제도 동반하고 있습니다.

인증 및 세션 관리 취약성

로그인 처리 로직에서 세션 고정(Session Fixation) 공격에 취약함이 확인되었습니다. 인증 전후로 세션 ID를 재발급하지 않아 공격자가 미리 발급받은 세션 ID를 강제로 고정하여 피해자의 권한을 가로챌 수 있는 상태입니다. 또한, 비밀번호 추측 방지 대책이 미흡하고 쿠키에 세션 정보가 평문으로 포함될 가능성이 커, 관리자 계정 등 중요 페이지로의 비인가 접근 위험이 매우 높게 평가됩니다.

파일 업로드 기능의 보안 위험

사용자 프로필 이미지 업로드 기능 등에서 파일 확장자 및 MIME 타입 검증이 이루어지지 않아 악성 웹 셸(Webshell) 업로드가 가능합니다. 업로드된 파일을 실행 가능한 위치에 저장하고 호출할 수 있는 환경은 서버의 OS 제어권을 탈취당할 수 있는 치명적인 고위험 취약점으로, 즉각적인 코드 수정 및 서버 하드닝이 필요합니다.

데이터 전송 및 환경 보안 미흡

로그인 등 개인정보를 전송하는 구간에서 TLS/SSL 암호화 적용이 누락되어 데이터가 평문으로 유출될 가능성이 큼니다. 종합적으로 본 서비스는 현재 비즈니스 로직과 보안 정책의 괴리로 인해 계정 탈취, 중요 정보 유출, 시스템 장악 등 심각한 보안 사고가 발생할 수 있는 상태입니다.